COLLEGE ATTENDANCE MANAGEMENT SYSTEM

Prototype Requirements & Architecture Plan

Version 1.1 | Finalized planning baseline | 9 October 2026

STATUS: POLICY DEFAULTS SET

This version resolves the earlier open policy choices for Prototype v1.0. It is still a specification, not proof that software is implemented, tested, or approved for real student data.

Deliverables: Student Android application + Admin/Teacher Windows executable

Architecture direction: React + TypeScript shared UI, Capacitor/native Android integration, Tauri 2 Windows desktop, Supabase Auth/PostgreSQL/Storage/Edge Functions.

Scope boundary: facial verification and all offline attendance modes are future-phase items, not part of Prototype v1.0.

Decision discipline

Policy defaults below are considered selected for implementation planning. Actual campus coordinates, institutional record-retention approval, production cloud region, and real-device benchmark results must be verified during deployment/testing; they cannot be honestly pre-filled without the campus environment and built application.

1. Purpose and core outcome

Build a reliable, fast attendance platform with three roles: Administration, Teacher and Student. The student uses an Android app; administration and teachers use a Windows executable. The clients share one backend and one authoritative attendance database.

Prototype v1.0 will use online-first Supabase. Attendance is confirmed only after backend validation and a successful database commit. A client-side success animation or locally cached status is not authoritative.

Goals

- Reduce casual proxy attendance using a short-lived session QR, one registered Android device per student, location checks and OS device authentication.
- Keep attendance corrections transparent and auditable instead of silently editing records.
- Make check-in simple: permission preflight, prepared scanner, clear countdowns, actionable errors and minimal server round trips.
- Keep the architecture modular so future face verification and offline modes can be added without rewriting core attendance records.

2. Scope locked for Prototype v1.0

Feature	Prototype v1.0 decision
Student client	Android application; Android 10 / API 29 or newer as the initial supported baseline.
Admin/Teacher client	Signed Windows 11 x64 executable; Windows 10 may be used only for internal compatibility checks, not the primary supported deployment baseline.
Backend	Supabase Auth + PostgreSQL + Row Level Security + server-side Edge Functions/database transactions.
Attendance-time checks	Session-bound QR, teacher/session anchor distance check, location freshness/accuracy, one active registered device, OS-authenticated device key, duplicate/replay protection.
Face verification	Deferred entirely to a future phase. No face matching, liveness capture, face embedding or reference-photo upload is required in v1.0.
Offline attendance	Not supported in v1.0. Network failure produces retry/pending/error messaging and an audited teacher exception path; it never claims offline-confirmed attendance.
Manual attendance	Allowed for a genuine late/missed check-in or verification failure, with a reason and immutable audit event.

3. Roles and permissions

Capability	Administration	Teacher	Student
Manage roster / sections / rooms	Authorized admin	No	No
Manage teacher assignments	Yes	No	No
Start attendance session / show QR	Policy/configuration	Assigned sections only	No
Check in / view own attendance	Can audit	Can view assigned classes	Own records only
Manual mark/correction	Restricted and audited	Assigned class; reason required	Submit a correction request
Device reset/replacement	Approve and revoke old device	No	Request through admin

Audit logs: administration has restricted access; teachers may review their own manual actions as needed; students cannot view security logs.

Enforce permissions on the backend for every request. UI visibility is not authorization. Use default-deny rules, least privilege and RLS for exposed data.

4. Exact QR and check-in policy

Policy item	Locked prototype default
QR expiry	90 seconds, measured by backend/server time.
QR rotation	Issue a new unique challenge every 90 seconds while attendance is open. Only one QR challenge is active per session; older challenges cannot start new attempts.
Post-scan completion	45 seconds from the first valid scan to complete required checks and submit. This attempt deadline is separate from QR expiry.
Token contents	Opaque, high-entropy, session-bound token/challenge ID; no student PII. Server stores issued-at/expiry/session/teacher and consumed state.
Replay / duplicate control	A challenge cannot be replayed to create unlimited attempts. Enforce server-side consumed state, rate limits and a unique attendance record per student + session. Legitimate in-progress attempt remains valid to its 45-second deadline even if QR rotates.
Normal scan window	Teacher may open the session up to 10 minutes before scheduled start. Student QR check-in remains open until scheduled class end.
Extension	Teacher may extend the scan window up to 15 minutes after scheduled end only with a recorded reason. The extension is displayed and audited.
Late after scan window	Student cannot self check-in after the session closes. Teacher may record attendance manually for a valid reason within the correction policy in Section 8.
Time authority	Use server/database time for expiry and deadlines; never trust the student device clock.

Check-in sequence

1. Teacher opens the assigned class session. The app captures a location anchor when supported and confirms that the teacher/session anchor is allowed for that campus/room.
2. Backend creates the session and its first 90-second QR challenge. The teacher screen shows the expiry countdown and rotates challenges automatically.
3. Student scans before expiry. Backend validates the QR, session state, student eligibility, device binding and duplicate status, then creates a unique 45-second attempt.
4. Student app obtains a fresh location fix, checks distance against the session anchor, invokes native Android OS authentication and signs a server challenge with the registered device key.
5. Backend validates the signed challenge, device status, time limits, location evidence, session authorization and uniqueness in a transaction.
6. Only after commit does the app show “Attendance confirmed” with the server timestamp. Network timeout after submission must query the attempt/record before retrying to avoid accidental duplicates.

5. Location anchor and 100-metre geofence

PROTOTYPE THRESHOLD

A student location must be within 100 metres of the active attendance session anchor. This is a starting policy to test on real phones, not a claim that GPS is accurate to 100 metres in every building.

Anchor priority and validation

- Primary: capture the teacher QR-generating Windows device location when Windows Location Services provides a fresh and sufficiently accurate fix. Record the anchor coordinates, accuracy, timestamp and source when the session opens.
- The teacher anchor itself must fall within the administrator-configured approved campus/room area and the teacher must be assigned to the selected section. If outside the allowed area, block session QR issuance.
- Desktop devices may not have reliable GPS. In that case, the teacher must select an administrator-configured classroom anchor; the system records anchor_source = approved_room_anchor. Never silently substitute the user's estimated location or an unapproved coordinate.
- Student location must be captured at check-in, no older than 15 seconds and reported accuracy no worse than 50 metres. Calculate distance server-side; accept only at 100 metres or less from the session anchor and only if inside the approved campus area.
- If a fresh accurate fix is unavailable, allow a retry and clear explanation. If it still fails, route to the audited teacher exception process; do not label the student fraudulent automatically.

Campus coordinates remain a deployment input

Administration must configure actual campus boundaries and classroom anchors from verified site coordinates before a pilot. The requirement sets the 100-metre policy but does not invent Ganpat University or any building's coordinates. Test indoor GPS, Wi-Fi-assisted location, large buildings, and boundary cases before rollout.

Location is a supporting signal only. It can be inaccurate or spoofed; the policy combines it with the QR, device binding, native authentication, server checks and audit trails.

6. Android authentication and device binding

Device swap/loss: admin verifies replacement, revokes old keys/sessions and audits the change. OS authentication checks registered-device access, not the holder's identity.

Item	Locked prototype default
Supported Android	Android 10 / API 29+ as the initial baseline; publish a tested device/OS compatibility list after QA.
OS prompt	AndroidX BiometricPrompt using strong biometrics when available, with secure device credential fallback allowed (PIN, pattern or password configured on the device).
Device without secure lock	Require the student to set a supported secure screen lock before enrollment/check-in; do not silently bypass authentication.
Registered device limit	Exactly one active Android device per student.
Binding	Create an installation/device public-private key pair through Android Keystore where supported; prefer hardware-backed keys. Server binds the public key to the student and device record.
Challenge signing	After OS authentication, use the protected private key to sign a short-lived server challenge. The backend verifies the signature and key status. A client-reported "biometric success = true" alone is insufficient.

7. Face verification: future phase only

NOT IN PROTOTYPE v1.0

Do not build or collect facial data in the first prototype. Do not upload roster face photos, capture enrollment selfies, create face embeddings or perform attendance-time facial recognition in v1.0.

Future-phase entry criteria

- Obtain institutional approval, a privacy notice and an appropriate consent/alternative process before processing real student biometric data.
- Evaluate model and anti-spoof/liveness candidates separately. Do not consider previously discussed OpenCV YuNet/SFace or MiniVision anti-spoof candidates approved until license terms, model provenance, device support and permitted use are reviewed.
- Test on the actual target Android phones and under varied lighting, camera quality, pose, skin tone and accessibility conditions. Measure false accepts, false rejects, latency and spoof-attempt outcomes; do not invent performance claims.
- Prefer not to persist raw live captures. Proposed future retention: discard temporary live captures immediately after decision and in all cases within 15 minutes; delete the admin reference photo within 30 days after successful enrollment unless a documented, approved purpose requires otherwise.
- Do not store face embeddings by default. If future design demonstrates a need to store them, require separate review, access controls, encryption, retention rules and deletion testing.
- Provide an audited human review and a non-biometric exception route for failed verification or students unable to complete the procedure.

8. Manual attendance, late arrivals and finalization

Rule	Default policy
Allowed reasons	Late arrival for a genuine reason; campus/college duty; medical/emergency reason; transport disruption; QR/app/network/location/authentication failure; other with required explanation.
During the class	Assigned teacher can manually mark a student present or correct an entry with a mandatory reason. Student identity/section and session must match.
Teacher edit window	Until 24 hours after scheduled session end. Every edit is audited with actor, timestamp, session/student, old status, new status and reason.
Automatic finalization	Attendance finalizes automatically 24 hours after scheduled session end. Before finalization, teacher can review missing/error cases.
Post-finalization changes	From 24 hours through 7 calendar days after session end, only an authorized administrator may amend attendance, with reason and approval/audit record. Notify the teacher and student of the adjustment.
Beyond 7 days	No routine edits. Require exceptional written justification and a second authorized administrative approver; retain a permanent audit event.
Student dispute	Student can request correction but cannot edit directly. Review is tracked; history must never be silently overwritten.

9. Data minimization and retention baseline

These are prototype defaults for institutional review, not a statement of legal retention requirements. A college policy or applicable law that requires a shorter/longer period must be reviewed and documented before a real pilot.

Data category	Prototype retention / handling
Face reference photos and live face captures	Not collected in v1.0. If face verification is approved in a later phase: reference photo deleted within 30 days after successful enrollment unless an approved, documented need exists; temporary live capture deleted immediately after decision and no later than 15 minutes.
Face embeddings / templates	Not created or stored in v1.0. Future phase default: do not persist; require a separately approved justification if proposed.
Exact student GPS coordinates	Store only what is needed for dispute/security analysis; delete exact coordinates after 30 days. Retain coarse verification outcome, computed distance band and reported accuracy for up to 180 days.
Verification metadata	Store pass/fail, reason code, server timestamp, attempt/session IDs, key/device reference and minimal accuracy/distance metrics. Keep up to 180 days, then delete or anonymize unless linked to an open dispute/security incident.
Attendance records and manual adjustments	Proposed default: retain for 3 academic years after the academic year ends, subject to institutional record policy. Corrections remain linked to original status.
Audit/security logs	Keep sensitive admin/device/reset/manual-change/access events for 2 years after the event. Restrict read access; do not log passwords, secrets, raw tokens, or unnecessary location/biometric data.
Account/device metadata	Delete or de-identify within 1 year after account deactivation/exit unless required for an open dispute, security incident or institutional record policy.
Backups	Use backup retention set out in Section 11. Deletion from live tables is not considered complete until the record expires from backups under the approved backup lifecycle.

Implement scheduled deletion jobs, log deletion outcomes without logging deleted content, and test deletion in both live tables and backup lifecycle. Restrict photo/biometric future-phase data by role and encrypt it at rest and in transit.

10. Initial data model and backend invariants

Core entities: users, students, teachers, courses_sections, teacher_assignments, rooms_locations, registered_devices, attendance_sessions, qr_challenges, checkin_attempts, attendance_records, manual_adjustments, verification_attempts, audit_logs and retention_jobs.

- One active device per student: enforce in the database, not only in the UI.
- One authoritative attendance record per student + session: unique database constraint and idempotent server operations.
- QR challenges include session ID, random challenge ID, issued/expiry timestamps, status and anchor reference. Never treat QR text alone as proof that attendance is committed.
- Use a transaction or database-side operation for final attendance validation + unique insert. On any rejection/failure, do not partially commit a present record.
- All student reads are self-only; teachers are limited to assigned sections; admin access is restricted, role checked and audited.
- Use RLS on exposed tables. Privileged secrets/service-role keys remain server-side and never enter Android or Windows client bundles.
- Use UTC server timestamps; present local campus time in the UI. Handle daylight-saving/time-zone assumptions explicitly if future sites differ.

11. Architecture, hosting, backups and monitoring

Layer	Selected direction
Shared UI	React + TypeScript + Vite; shared forms, validation, role-aware screens and API client separated from platform-specific code.
Student Android	Capacitor Android shell with native plugins/bridge for camera QR scanning, Android location APIs and AndroidX BiometricPrompt/Keystore. Prototype does not need face capture.
Admin/Teacher Windows	Tauri 2 Windows x64 package for a signed desktop executable; Windows Location Services adapter where supported; admin-configured room anchor fallback.
Backend	Supabase Auth, PostgreSQL, RLS, Storage only for approved non-biometric files, Edge Functions and database transactions/RPC for sensitive operations.
Source control	Private GitHub repo is source of truth. Lead owns repo; teammates use individual collaborator access. Protect main after verifying Lovable sync behavior.
Secrets	Publishable key may be shipped only with correct RLS protections. Secret/service-role keys, database credentials, signing keys and production secrets live only in trusted server/secret storage; never commit .env files.
Environments	Separate development/staging and production projects. Synthetic test data in dev; no production student data in personal/dev environments.

Hosting and backup policy

- Before a real pilot, select the closest suitable Supabase hosting region after confirming current availability, institutional data-residency requirements and approved budget. Do not assume a particular region is available without checking the dashboard.
- For a real attendance pilot, use a paid Supabase plan with automated daily database backups, or an equivalent managed arrangement. Supabase documentation currently describes daily backups for Pro/Team/Enterprise, with 7/14/30-day retention respectively; verify plan details at deployment.
- Additionally run a weekly encrypted logical export to a separate access-controlled storage location, retain weekly copies for 30 days, and keep them outside the app repository. Never use GitHub as a database-backup vault.
- Perform a restore rehearsal to a non-production project before pilot launch and monthly during the pilot. Record duration, completeness and any failed steps. A backup that has never been restored is not a verified recovery plan.
- Monitor API latency/error rate, failed QR attempts, duplicate/replay rejections, geofence failures, device-signature failures, manual override rates, admin privilege changes, function/database errors and backup-export success. Alert an assigned owner; review daily during the first two pilot weeks.
- Pilot progression: internal synthetic-data testing first; then a small, approved volunteer group; then a limited class/section pilot only after privacy/security approval and restore test. Maintain a rollback path and a manual attendance fallback.

12. Offline roadmap and conflict policy

Phase	Target	Rule
Phase 1 - v1.0	Online-first Supabase	No offline-confirmed attendance. Network failure shows retry / not confirmed and can lead to audited teacher manual attendance.
Phase 2	Internet down, campus LAN available	Local gateway/server and local database authenticate against a synchronized campus roster. Every local operation gets a unique ID and device/session timestamp; sync to cloud idempotently after internet returns.
Phase 3	Student device itself offline	Local queue only; status remains PENDING_SYNC, never CONFIRMED until server validates. Stronger proxy/revocation/duplicate guarantees cannot be promised while disconnected.

Future conflict resolution defaults

- Each offline action carries a UUID operation ID, session ID, student ID, device key ID, client event time, monotonic sequence where available, and later server receipt time.
- Server receipt/validation time is authoritative for acceptance. Do not silently use “last write wins” to resolve attendance status.
- Duplicate operation ID is idempotent. Multiple conflicting attendance actions create a conflict record and require an auditable human resolution.
- Offline records cannot confirm attendance against revocations or cross-device duplicates that occurred after the last sync. Surface this reduced assurance to admins.

13. Build sequence

1. Freeze this v1.1 baseline, create role/permission matrix and database schema/migrations.
2. Create private GitHub repository, separate development/staging Supabase project, environment variable setup and secret-handling checks.
3. Implement authentication, roster import, roles, course/section assignments, room anchors and RLS tests using synthetic data.
4. Build Admin/Teacher UI and Windows Tauri packaging; implement approved room-anchor fallback plus teacher location capture where available.
5. Build Android Capacitor app with camera QR scanner, permission preflight, fresh location fix, native authentication and Keystore challenge signing.
6. Implement 90-second QR rotation, 45-second attempt deadline, replay/duplicate prevention and transactional attendance result.
7. Add manual attendance, 24-hour finalization, admin correction workflow, device replacement/revocation, audit logs and retention jobs.
8. Test on real Android phones and actual classroom/Windows hardware; tune only through documented test results. Confirm performance and restore ability before pilot.
9. Defer face verification and offline modes to separate approved future phases; do not let these delay or expand v1.0 scope.

14. Testing and acceptance criteria

Test area	Minimum acceptance evidence
QR timing	Expired QR rejected; valid scan creates attempt with 45-second deadline; QR rotations every 90 seconds; concurrent/replay attempts cannot create duplicates.
Location	Teacher anchor must be within approved campus area; student must be <=100 m, fix age <=15 sec and reported accuracy <=50 m; poor fixes trigger retry/review rather than fraud accusation.
Android auth/device	Test strong biometric, secure credential fallback, no secure lock, OS/device versions, cancelled/failed prompt, revoked key and device replacement. Tampered “auth succeeded” client response must not pass signature checks.
Attendance integrity	Exactly one student/session record; server commit before success UI; timeout/retry remains idempotent; concurrent requests cannot double-mark.
Manual/finalization	Mandatory reason; valid actor/section; teacher window closes at 24h; admin-only corrections until day 7; exceptional dual approval after day 7; audit cannot be silently edited.
Roles/data	RLS test matrix; student cannot read others; teacher cannot edit unassigned sections; service secrets absent from bundles/repository; audit access restricted.
Performance	Report median and p95 time from scan to confirmed response on actual phones/network; report GPS/auth failure rates and network timeouts. 45 seconds is a deadline, not a guaranteed average completion time.
Backup/restore	Successful restore to staging from independent backup; verify row counts, constraints, session/attendance relations and documented recovery steps.
Pilot safety	Written approval, user notice, defined support contact, manual fallback, synthetic test completed, incident/rollback plan and no unresolved critical security failures.

Do not claim “100% proxy-proof,” verified model accuracy, successful anti-spoofing, or guaranteed speed until measured. Use consenting volunteers and synthetic records for prototype tests.

15. Known limits and mitigations

Risk	Mitigation / residual limit
Friend uses a student’s unlocked phone	OS auth and registered key raise friction, but no attendance-time face check means the person holding the phone may not be the enrolled student.
GPS spoofing / indoor inaccuracies	Use fresh accuracy-bounded fix, teacher/session anchor, approved campus boundary, server-side validation and manual review. GPS alone is not identity proof.
Teacher computer has no location fix	Use an admin-approved room anchor and log anchor source; never silently use invented coordinates.
Network failure after scan	Query attempt status/idempotently retry. Do not show confirmed without backend evidence. Teacher can apply manual exception with reason.
Misuse of manual attendance	Role restriction, required reason, bounded windows, append-only audit, post-finalization admin approval and monitoring of override rates.
Face-data privacy and spoofing	Not collected in v1.0. Future phase requires approved model/license, real-device false-accept/false-reject/spoof testing, retention and deletion controls.
No internet/offline sync conflict	Out of scope in v1.0. Future records stay pending until validation and conflicts are never silently overwritten.

16. Finalized decisions and deployment inputs

Decision	Current baseline
QR expiry / post-scan deadline	90 sec / 45 sec
QR rotation / class window	New QR every 90 sec; open up to 10 min before start through class end; optional audited extension up to 15 min after scheduled end.
Location	Student <=100 m from active teacher/session anchor; teacher anchor inside approved campus area; student fix <=15 sec old and <=50 m reported accuracy.
Authentication fallback	Strong biometric preferred; secure Android device credential fallback allowed; minimum Android API 29 for initial support.
Device limit/recovery	One active device per student; admin-verified replacement; old key immediately revoked.
Manual and finalization	Teacher edits through 24 h after session end; auto-finalize at 24 h; admin correction to day 7; beyond 7 days exceptional dual approval.
Face verification	Entirely future phase; no face data collected in v1.0.
Retention	Future-face data not collected; if later approved, capture/photo/metadata defaults in Section 9; attendance and logs follow section 9 retention baseline.
Architecture	React + TypeScript; Capacitor/native Android; Tauri 2 Windows; Supabase Auth/Postgres/RLS/Edge Functions.
Backups/monitoring	Daily managed backups for production pilot, weekly encrypted independent export retained 30 days, monthly restore test, daily monitoring in pilot weeks 1-2.
Offline	Phase 2 campus LAN local server; Phase 3 device queue; both outside v1.0.

Deployment inputs that must be supplied/verified before a live pilot

- Actual campus boundary and classroom anchor coordinates, confirmed on site by authorized staff.
- Selected Supabase region/plan, institutional approval, access owners and backup storage location.
- Real-device results for Android versions, Windows location availability, GPS accuracy in the actual teaching spaces, check-in p50/p95 and biometric/device credential behavior.
- Institutional approval of final record-retention periods and privacy notice. These are environmental validation tasks, not unresolved product-policy choices.

17. Implementation principles

- Backend is authoritative; the UI never invents attendance success.
- No biometric face processing or face imagery in v1.0.
- No secret keys in shipped clients or source control.
- Every manual adjustment, device recovery and privileged administrative action is audited.
- Fail safely: retry, pending status or human review is better than silent failure or unsupported fraud accusations.
- Test on real target devices before setting public claims, and keep future face/offline work modular.

18. Platform references

These official documents inform implementation/security details; verify them again during implementation because platform behavior and plan terms can change.

- **Android BiometricPrompt API reference:** https://developer.android.com/reference/android/hardware/biometrics/BiometricPrompt.html
- **Supabase database backups and retention:** https://supabase.com/docs/guides/platform/backups
- **Supabase securing data / RLS:** https://supabase.com/docs/guides/database/secure-data